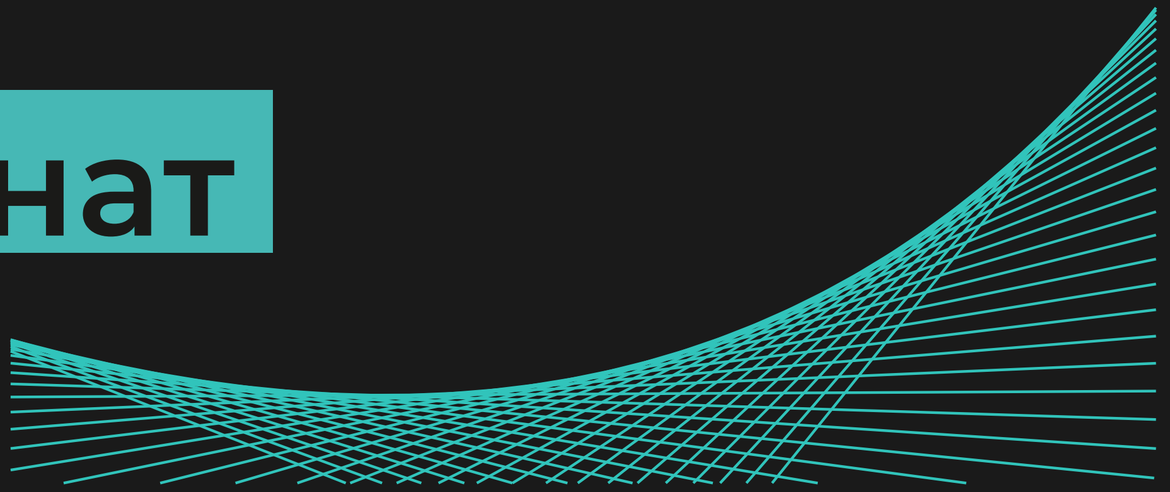
Защита проекта

55.6954
N
37.3907
E

Кейс чемпионат *В ПОТОКЕ*



Кейс: «Онлайн-чаевые: платформа для ресторанов»

Команда: Team Enjoy

Состав: Студенты ИУ-5 МГТУ им Н.Э. Баумана, Макаров М. И., Стегунов А. В., Кубанов Т. А., Колюжин В. Н.





ТОП ИТ КНИГУ

Центр реализации образовательных программ топ-уровня в сфере ИТ МГТУ им. Н.Э. Баумана

Проблема

55.6954° N
37.3907° E

1. Сети ресторанов «Вкус-сервис» необходимо ввести онлайн чаевые через QR на чеке

2. Клиент сканирует QR-код на чеке, выбирает процент чаевых и платит.

3. На рынке РФ уже есть решения, но в Юго-восточной Азии ниша свободна: продукт можно масштабировать

Центр реализации образовательных программ топ-уровня в сфере ИТ МГТУ им. Н.Э. Баумана

Роли

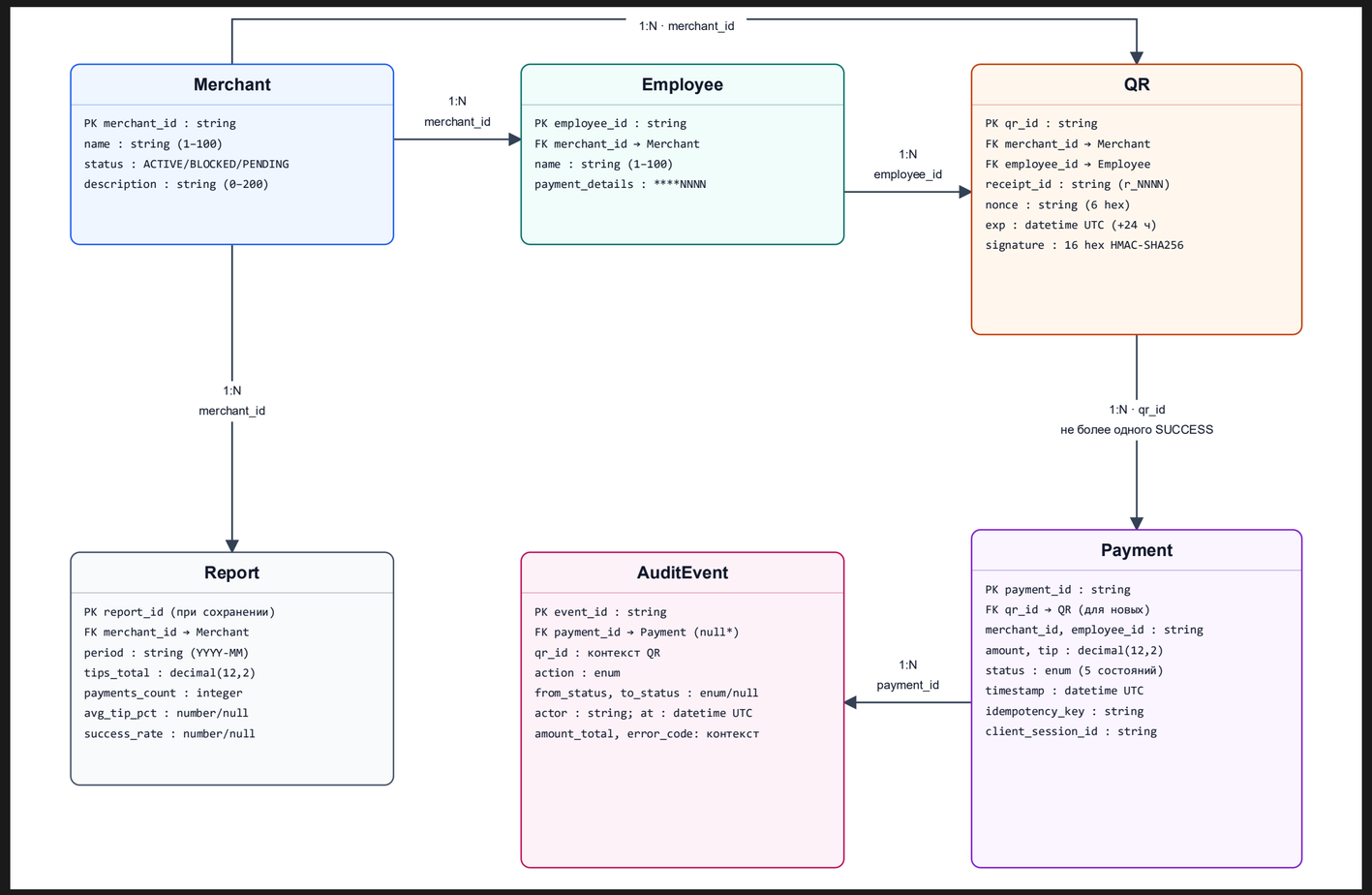
1. Мерчант
2. Официант
3. Клиент
4. Админ

Действие	Мерчант	Официант	Клиент	Администратор
Регистрация в платформе	+	-	-	+
Генерация QR на чек	+	-	-	-
Просмотр своих чаевых	+	+	-	+
Сканирование QR	-	-	+	-
Оплата чаевых	-	-	+	-
Просмотр отчёта по заведению	+	-	-	+
Блокировка мерчанта	-	-	-	+
Изменение справочников	+	-	-	+

55.6954° N
37.3907° E

Данные и модель

55.6954° N
37.3907° E



1. Мерчант
2. Официант
3. Клиент
4. Админ

QR и подпись

55.6954° N
37.3907° E

1. Для шифровки используется HMAC-SHA256

2. Для оптимизации используется TTL 24h

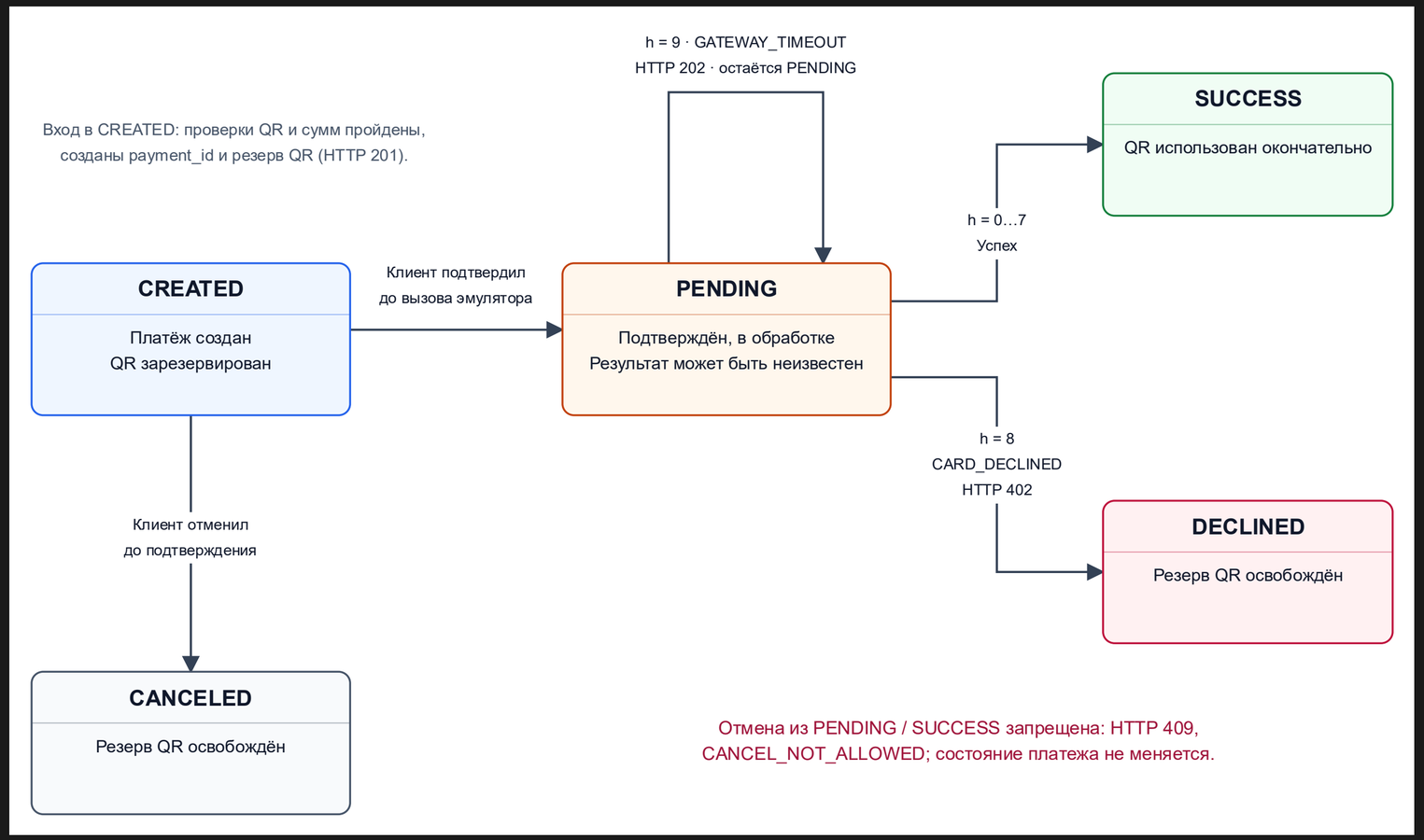
3. Для дополнительной защиты используется одноразовый nonce

Payload

Название	Тип	Ограничение	Пример
merchant_id	string	Соответствует паттерну m_NNN	qr_001
employee_id	string	Соответствует паттерну e_NNN	m_001
receipt_id	string	Соответствует паттерну r_NNN	e_001
nonce	string	6 hex символов, криптостойкий одноразовый токен	c82561
exp	string	Формат ISO 8601	2025-11-01T23:59:00Z
signature	string	Первые 16 hex символов от HMAC-SHA256 от secret	68d0f361ac38c12b

Диалог и платёж

55.6954° N
37.3907° E



1. Перед клиентом появляется приветствие и просьба выбрать процент для чаевых.
2. Клиенту показывается итоговая сумма.
3. Клиент подтверждает платёж.
4. После прохождения платежа показывается итоговое окно.

Демо

55.6954° N
37.3907° E

CLI на qr_001

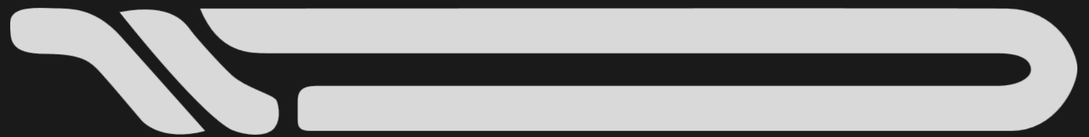
python 04_прототип.py 04_примеры/t3_1_success.json

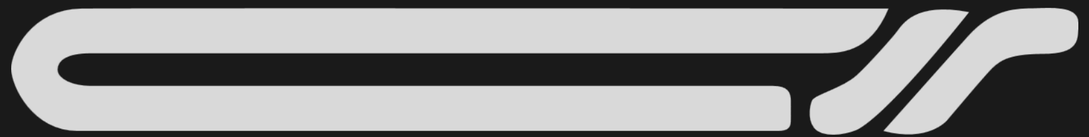
```
{
        "payment_id": "p_demo_001",
        "status": "SUCCESS",
        "amount_total": 668.85,
        "tip_amount": 31.85,
        "error_code": null
}
```

CLI на qr_003

python 04_прототип.py 04_примеры/t3_2_declined.json

```
{
        “payment_id”: “p_demo_003”,
        “status”: “DECLINED”,
        “amount_total”: 1047.65,
        “tip_amout”: 136.65,
        “error_code”: “CARD_DECLINED”
}
```









55.6954° N
37.3907° E

Тесты

Тест	Описание	Ожидаемый результат	Совпадение с ожидаемым результатом
Т3-1	qr_001, base=637.00, tip_pct=5	**SUCCESS, amount_total=668.85, tip=31.85**	+
Т3-2	qr_003, base=911.00, tip_pct=15	**DECLINED, CARD_DECLINED**	+
Т3-3	QR с испорченной надписью	**INVALID_QR (422) или QR_EXPIRED(410), платёж не создан**	+
Т3-4	QR с таким же indemptotency_key	**Тот же payment_id, одна строка в payments.csv**	+
Т3-5	Отменённый до подтверждения платеж	**CANCELED, отмена из PENDING → 409**	+

Риски

55.6954° N
37.3907° E

Угроза	Актив под угрозой	Метод защиты
Подделка QR	**Деньги клиента**	Использование HMAC-SHA256 + Регулярная смена секрета
Двойное списание	**Деньги клиента**	Использование nonce и TTL 24h
Кража реквизитов официанта	**Данные официанта**	Хранить данные в шифрованном виде, маскирование логов и ограниченный доступ по ролям
Манипуляция официанта	**Деньги клиента и данные компании**	Проверять привязку к receipt_id, рассчитывать платежи на сервере, показывать клиенту итоговую сумму для оплаты, логирование действий сотрудника

Центр реализации образовательных программ топ-уровня в сфере ИТ МГТУ им. Н.Э. Баумана

Спасибо за внимание

Команда: Team Enjoy

Состав команды:

1. Макаров М. И.
2. Стегунов А. В.
3. Кубанов Т. А.
4. Колюжин В. Н.

